

VULNERABILITY ASSESSMENT REPORT

Passive Security Assessment of Altoro Mutual
(IBM Demo Banking Application)

Prepared By: Maanas Sri Udbhav Maddula
Future Interns – Cyber Security Task 1
Assessment Date: 14 June 2026

1. Executive Summary

A passive vulnerability assessment was conducted on the publicly accessible demonstration banking application, Altoro Mutual (IBM Demo Site), to identify common security weaknesses without causing disruption to the target environment.

The assessment focused exclusively on publicly available pages and adhered to strict ethical guidelines. OWASP ZAP, Browser Developer Tools, and Nmap were utilized to identify configuration weaknesses, missing security headers, information disclosure issues, and exposed services.

A total of 12 findings were identified:

- 6 Medium Risk Findings
- 3 Low Risk Findings
- 3 Informational Findings

No exploitation attempts, brute-force attacks, denial-of-service activities, or intrusive testing techniques were performed during this assessment.

2. Assessment Overview

2.1 Target Website

Website: <https://demo.testfire.net>

Application Name: Altoro Mutual (IBM Demo Banking Application)

Assessment Type: Passive Vulnerability Assessment

Assessment Date: 14 June 2026

2.2 Scope

- Public-facing pages only
- Passive scanning
- Header analysis
- Configuration review
- Service exposure analysis

2.3 Out of Scope

- Exploitation
- Login bypass
- Brute-force attacks
- Denial-of-Service attacks
- Data modification

2.4 Objectives

The objectives of this assessment were to:

- Analyze a public website for common security weaknesses.
- Identify exposed services and insecure configurations.
- Evaluate browser security headers.

- Classify risks using business-friendly language.
- Recommend practical remediation steps.
- Present findings in a professional audit report.

3. Methodology

3.1 Phase 1 – Manual Exploration

Public pages of the application were browsed to understand functionality and collect passive evidence.

Pages visited:

- Homepage
- Personal Banking
- Loan Products
- Search Functionality
- Login Page

3.2 Phase 2 – OWASP ZAP Passive Analysis

OWASP ZAP was configured as a proxy to inspect traffic. Activities performed:

- Passive vulnerability scanning
- Alert review
- History analysis
- Security header inspection

No active attacks or exploitation techniques were used.

3.3 Phase 3 – Browser Developer Tools

Chrome DevTools were used to inspect:

- Response headers
- Cookies
- Server information
- Cache-related information

3.4 Phase 4 – Nmap Service Enumeration

Basic service enumeration was conducted using:

```
nmap -sV demo.testfire.net
```

The objective was to identify publicly exposed services without aggressive scanning.

3.5 Tools Used

Tool	Purpose
OWASP ZAP	Passive vulnerability analysis
Browser Developer Tools	Header and cookie inspection
Nmap / Zenmap	Service enumeration

Microsoft Word	Report preparation
----------------	--------------------

4. Findings Summary

Severity	Count
Medium	6
Low	3
Informational	3
Total	12

5. Detailed Findings

Finding 1: Absence of Anti-CSRF Tokens

Risk Level	Medium
Description	The login form did not contain anti-CSRF protections.
Impact	Attackers may trick authenticated users into submitting unintended requests.
Recommendation	Implement anti-CSRF tokens and validate them server-side.

The screenshot shows a security tool interface with a sidebar on the left containing a list of findings. The main panel on the right displays the details for the finding 'Absence of Anti-CSRF Tokens'.

Findings List (Left Sidebar):

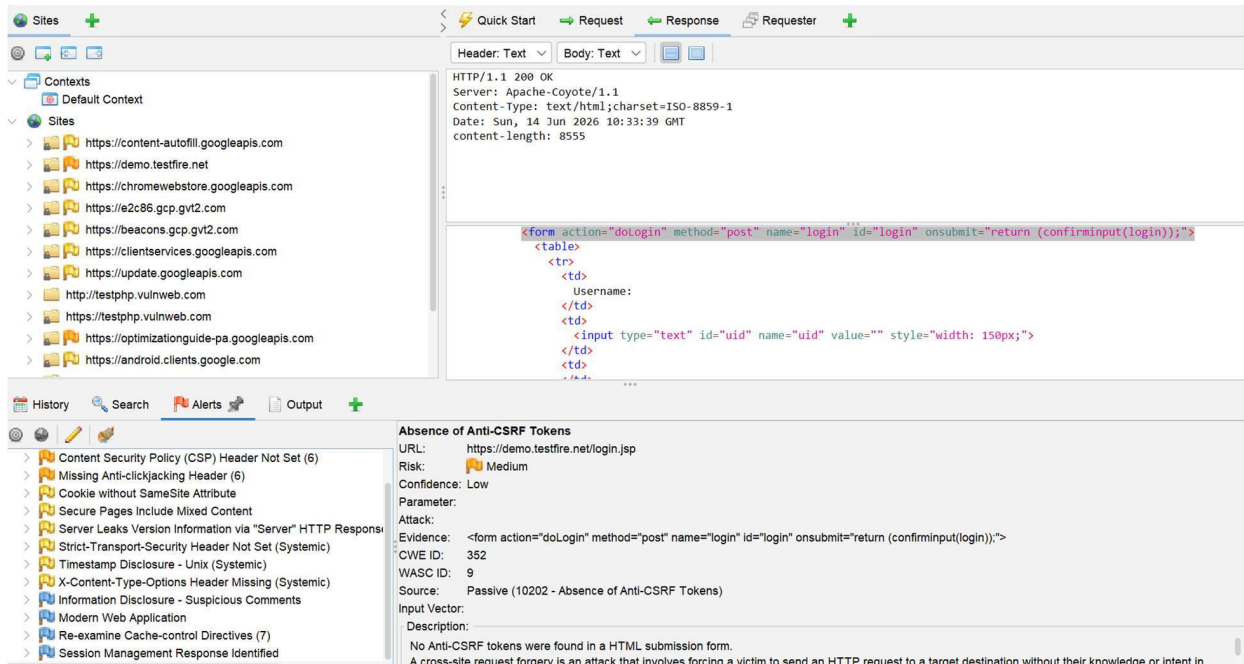
- > Content Security Policy (CSP) Header Not Set (6)
- > Missing Anti-clickjacking Header (6)
- > Cookie without SameSite Attribute
- > Secure Pages Include Mixed Content
- > Server Leaks Version Information via "Server" HTTP Response
- > Strict-Transport-Security Header Not Set (Systemic)
- > Timestamp Disclosure - Unix (Systemic)
- > X-Content-Type-Options Header Missing (Systemic)
- > Information Disclosure - Suspicious Comments
- > Modern Web Application
- > Re-examine Cache-control Directives (7)
- > Session Management Response Identified

Detailed View: Absence of Anti-CSRF Tokens

- URL:** <https://demo.testfire.net/login.jsp>
- Risk:** Medium
- Confidence:** Low
- Parameter:**
- Attack:**
- Evidence:** `<form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirm(input(login)));">`
- CWE ID:** 352
- WASC ID:** 9
- Source:** Passive (10202 - Absence of Anti-CSRF Tokens)
- Input Vector:**
- Description:**

No Anti-CSRF tokens were found in a HTML submission form.

A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in



Finding 2: Content Security Policy (CSP) Header Not Set

Risk Level	Medium
Description	No Content Security Policy header was detected.
Impact	Increases the impact of script injection attacks.
Recommendation	Implement an appropriate Content Security Policy.

Finding 3: Missing Anti-Clickjacking Header

Risk Level	Medium
Description	X-Frame-Options protection was not observed.
Impact	The application may be embedded into malicious websites.
Recommendation	Implement X-Frame-Options or frame-ancestors directives.

Finding 4: Cookie Without SameSite Attribute

Risk Level	Medium
Description	Session cookies lacked the SameSite attribute.
Impact	Cross-site requests may include authentication cookies.
Recommendation	Use SameSite=Lax or SameSite=Strict.

Cookie without SameSite Attribute	
URL:	https://demo.testfire.net/
Risk:	 Low
Confidence:	Medium
Parameter:	JSESSIONID
Attack:	
Evidence:	Set-Cookie: JSESSIONID
CWE ID:	1275
WASC ID:	13
Source:	Passive (10054 - Cookie without SameSite Attribute)
Alert Reference:	10054-1
Input Vector:	
Description:	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is

Finding 5: Secure Pages Include Mixed Content

Risk Level	Medium
Description	Secure pages referenced non-secure resources.
Impact	Weakens HTTPS protections.
Recommendation	Serve all resources over HTTPS.

Secure Pages Include Mixed Content	
URL:	https://demo.testfire.net/index.jsp?content=inside_contact.htm
Risk:	 Low
Confidence:	Medium
Parameter:	
Attack:	
Evidence:	http://fpdownload.macromedia.com/pub/shockwave/cabs/flash/swflash.cab#version=6,0,0,0
CWE ID:	311
WASC ID:	4
Source:	Passive (10040 - Secure Pages Include Mixed Content)
Input Vector:	
Description:	The page includes mixed content, that is content accessed via HTTP instead of HTTPS.

Finding 6: Strict-Transport-Security Header Not Set

Risk Level	Medium
Description	The HSTS header was absent.
Impact	Users may be vulnerable to protocol downgrade attacks.
Recommendation	Enable Strict-Transport-Security.

Finding 7: Server Version Disclosure

Risk Level	Low
-------------------	-----

Description	Server banner disclosed: Apache-Coyote/1.1
Impact	Technology disclosure may aid reconnaissance.
Recommendation	Suppress server version information.

Finding 8: X-Content-Type-Options Header Missing

Risk Level	Low
Description	Content sniffing protection was absent.
Impact	Browsers may incorrectly interpret file types.
Recommendation	Implement X-Content-Type-Options: nosniff.

X-Content-Type-Options Header Missing	
URL:	https://optimizationguide-pa.googleapis.com/downloads?name=1778511835&target=OPTIMIZATION_TARGET_NOTIFICATION_PERMISSION_PRE
Risk:	 Low
Confidence:	Medium
Parameter:	x-content-type-options
Attack:	
Evidence:	
CWE ID:	693
WASC ID:	15
Source:	Passive (10021 - X-Content-Type-Options Header Missing)
Input Vector:	
Description:	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform

Finding 9: Re-examine Cache-Control Directives

Risk Level	Low
Description	Caching behavior should be reviewed.
Impact	Sensitive information may be cached.
Recommendation	Use secure cache directives for sensitive content.

Finding 10: Timestamp Disclosure

Risk Level	Informational
Description	System timestamps were disclosed.
Impact	May assist attackers during reconnaissance.
Recommendation	Limit unnecessary metadata exposure.

Finding 11: Information Disclosure – Suspicious Comments

Risk Level	Informational
-------------------	---------------

Description	Comments were observed within application responses.
Impact	May reveal implementation details.
Recommendation	Remove unnecessary comments before production deployment.

Information Disclosure - Suspicious Comments

URL: <https://demo.testfire.net/login.jsp>

Risk:  Informational

Confidence: Medium

Parameter:

Attack:

Evidence: - To get the latest admin login, please conta

CWE ID: 615

WASC ID: 13

Source: Passive (10027 - Information Disclosure - Suspicious Comments)

Input Vector:

Description:

The response appears to contain suspicious comments which may help an attacker.

Finding 12: Session Management Response Identified

Risk Level	Informational
Description	Session handling mechanisms were identified.
Impact	No direct vulnerability observed.
Recommendation	Periodically review session management practices.

Session Management Response Identified

URL: <https://demo.testfire.net/>

Risk:  Informational

Confidence: Medium

Parameter: JSESSIONID

Attack:

Evidence: JSESSIONID

CWE ID:

WASC ID:

Source: Passive (10112 - Session Management Response Identified)

Input Vector:

Description:

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will

6. Nmap Results

Host: demo.testfire.net

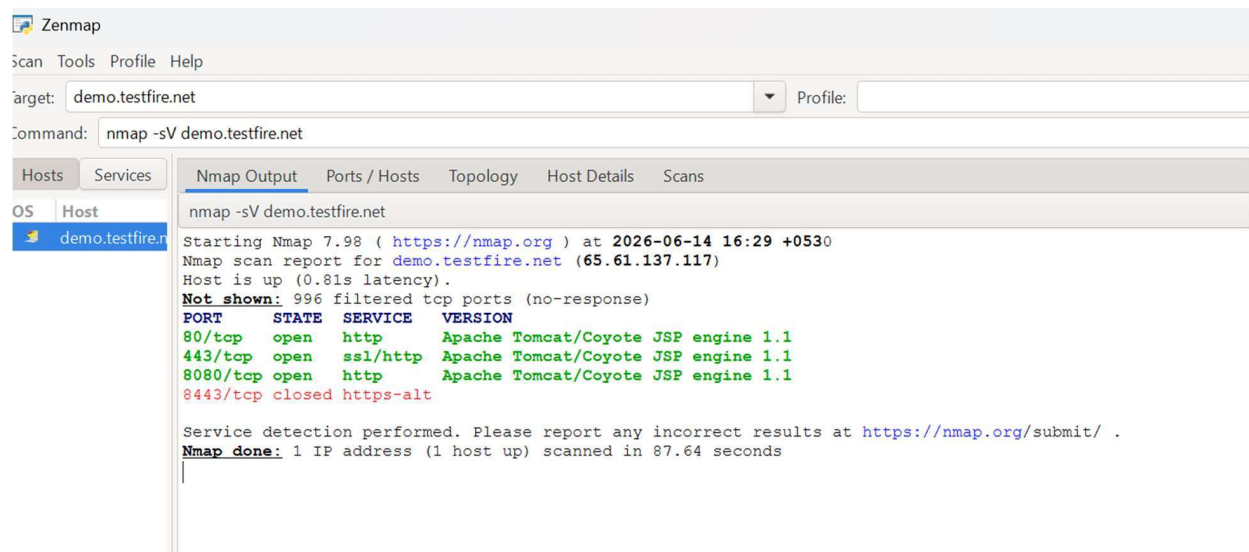
IP Address: 65.61.137.117

Host Status: Up

6.1 Open Services Identified

Port	State	Service	Version
80/tcp	Open	HTTP	Apache Tomcat/Coyote JSP Engine 1.1
443/tcp	Open	SSL/HTTP	Apache Tomcat/Coyote JSP Engine 1.1
8080/tcp	Open	HTTP	Apache Tomcat/Coyote JSP Engine 1.1
8443/tcp	Closed	HTTPS-alt	N/A

Observation: The server information identified through Nmap aligned with OWASP ZAP observations.



7. Browser Developer Tools Observations

7.1 Observed Headers

- Server: Apache-Coyote/1.1

7.2 Missing Security Headers

- Content-Security-Policy
- Strict-Transport-Security
- X-Frame-Options
- X-Content-Type-Options

7.3 Additional Observations

- ETag present
- Last-Modified header present
- Browser traffic successfully routed through OWASP ZAP proxy.

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=085A03010C8EAB6BD5ADE87D0B5BF452; Path=/; Secure; HttpOnly
Content-Type: text/html; charset=ISO-8859-1
Date: Sun, 14 Jun 2026 10:31:50 GMT
content-length: 9405
```

8. Risk Matrix

8.1 Medium Risk

- Absence of Anti-CSRF Tokens
- CSP Header Missing
- Anti-Clickjacking Header Missing
- SameSite Attribute Missing
- Mixed Content
- HSTS Header Missing

8.2 Low Risk

- Server Version Disclosure
- X-Content-Type-Options Missing
- Cache-Control Review

8.3 Informational

- Timestamp Disclosure
- Suspicious Comments
- Session Management Observation

9. Conclusion

The passive vulnerability assessment identified several opportunities to strengthen the application's security posture. The majority of findings were related to missing security headers and secure configuration practices rather than critical vulnerabilities. Implementing the recommended remediation measures would significantly improve resilience against common web-based attacks while reducing information exposure.

10. Ethical Statement

This assessment was conducted strictly within authorized read-only boundaries. No exploitation, credential attacks, denial-of-service testing, or intrusive techniques were conducted during this engagement.

11. Acknowledgment

This report was prepared as part of the Future Interns Cyber Security Task 1 initiative to demonstrate practical understanding of passive vulnerability assessment methodologies and ethical security practices.

Prepared by: Maanas Sri Udbhav Maddula

Programme: Future Interns – Cyber Security Track
Assessment Date: 14 June 2026